Design and apply context-aware access controls based on user identity, device posture, location, and application risk.

Stage – 1

Title:

Design and apply context-aware access controls based on user identity, device posture, location, and application risk.

Overview:

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principle of "never trust, always verify." By moving beyond location-based access, we aim to establish a security posture where trust is no longer implicit, and access is determined by granular context rather than network connectivity.

The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications, completely hiding the corporate network and IP address space from the internet. This ensures that users connect exclusively to the applications they are permitted to access, based on continuous identity verification and context, rendering the applications invisible to unauthorized users and preventing common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks.

Ultimately, this project will enforce a least-privilege access model, ensuring users and devices are granted the minimum required access necessary to perform their functions. By decoupling application access from network access, we will eliminate the risk of lateral movement across the network, as users have no visibility or connectivity to other hosts. This strategic move not only significantly enhances security by reducing the attack surface but also simplifies the user experience and reduces operational overhead associated with legacy remote access infrastructure, positioning the organization at the forefront of secure and efficient access management.

S.NO	NAME	CONTACT	COLLEGE
1	JIFI LOWRENCE	Srcw2326j160@srcw.ac.in	Sri Ramakrishna College Of Arts & Science for Women
2	SANKARI.D	Srcw2326j145@srcw.ac.in	Sri Ramakrishna College Of Arts & Science for Women
3	NANDHINI.T	Srcw2326j135@srcw.ac.in	Sri Ramakrishna College Of Arts & Science for Women
4	RAMYA. N	Srcw2326j139@srcw.ac.in	Sri Ramakrishna College Of Arts & Science for Women

List of Vulnerability:

S. No.	Vulnerability Name	CWE No.
1.	Cross-site scripting (stored)	79
2.	Broken Access Control	285
3.	SQL Injection	89
4.	Broken Authentication	285
5.	Insecure Direct Object Reference	639
6.	Security Misconfiguration	732
7.	Cross-Site Request Forgery	352
8.	Cleartext Transmission of Sensitive Information	319

Report:

1. Vulnerability

Cross-Site Scripting (Stored)

CWE/CVE: 79

OWASP Category: A03: Injection

Description:

Stored Cross-Site Scripting (XSS) occurs when malicious scripts are permanently stored within a web application, such as in databases, comment sections, or message boards. When users access the affected page, the stored script is executed in their browser. This allows attackers to run unauthorized code within the user's session and manipulate web content or steal sensitive information.

BusinessImpact:

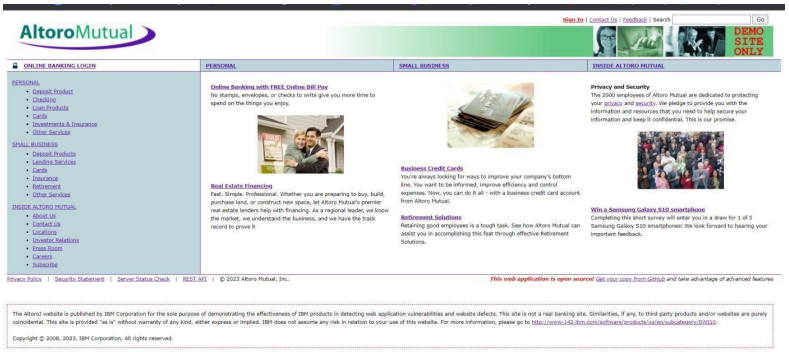
This vulnerability can allow attackers to hijack user sessions, steal login credentials, and perform actions on behalf of legitimate users. In severe cases, attackers may gain access to confidential data or administrative privileges, which can lead to major security breaches and damage to the organization's reputation.

Vulnerability path:

http://testfire.net/

Vulnerability parameter:

http://testfire.net/search.jsp?query='><script>alert('hacked')</script>



- In the search box we will input some code to perform the vulnerability.

Recommendation:

- When interacting with databases, use parameterized statements or prepared statements to avoid SQL injection, which can be a vector for XSS.
- Sanitize and validate all user inputs and ensure that any data displayed on the web page is properly encoded. Use output encoding libraries or functions to prevent script injection.

2. Vulnerability Name

Broken Access Control

CWE/CVE: 285

OWASP Category: A01: Broken Access Control

Description:

Broken Access Control occurs when an application fails to properly enforce restrictions on what authenticated users are allowed to do. Due to improper validation or missing authorization checks, attackers may gain access to restricted resources or perform actions beyond their permissions.

BusinessImpact:

If attackers exploit this vulnerability, they may view or modify sensitive information, delete data, or gain administrative privileges. This can cause financial loss, disruption of services, and damage to the organization's credibility.

Vulnerability path:

http://testfire.net/

Vulnerability parameter:

http://testfire.net/login.jsp

AltoroMutual

Sign In | Contact Us | Feedback | Search Go

DEMO SITE ONLY

ONLINE BANKING LOGIN | PERSONAL | SMALL BUSINESS | INSIDE ALTORO MUTUAL

PERSONAL
- Deposit Product
- Checking
- Loan Products
- Cards
- Investments & Insurance
- Other Services

SMALL BUSINESS
- Deposit Products
- Lending Services
- Cards
- Insurance
- Retirement
- Other Services

INSIDE ALTORO MUTUAL
- About Us
- Contact Us
- Locations
- Investor Relations
- Press Room
- Careers
- Subscribe

Online Banking Login

Username:

Password:

Login

Privacy Policy | Security Statement | Server Status Check | REST API | © 2023 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The AltoroJ website is published by IBM Corporation for the sole purpose of demonstrating the effectiveness of IBM products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. IBM does not assume any risk in relation to your use of this website. For more information, please go to http://www-142.ibm.com/software/products/us/en/subcategory/SW10.

Copyright © 2008, 2023, IBM Corporation, All rights reserved.

AltoroMutual

ONLINE BANKING LOGIN | PERSONAL | SMALL BU

PERSONAL
- Deposit Product
- Checking
- Loan Products
- Cards
- Investments & Insurance
- Other Services

SMALL BUSINESS
- Deposit Products
- Lending Services
- Cards

Online Banking Login

Username: admin

Password: •••••

Login

Recommendations:

- Ensure that the application has a robust authentication and authorization mechanism in place. Users should be authenticated before any sensitive actions are performed, and authorization checks should be conducted to verify that users have the necessary permissions for the requested operation.
- Ensure that session management is secure. Use strong session IDs, enforce session timeouts, and regenerate session tokens after login. Implement session fixation protection to prevent session hijacking.

3. Vulnerability Name

SQL Injection

CWE/CVE: 89

OWASP Category: A03: Injection

Description:

SQL Injection is a common web application vulnerability where attackers insert malicious SQL queries into input fields such as login forms or search boxes. If the application fails to properly sanitize the input, the database may execute these commands, allowing attackers to access or manipulate stored data.

Businessimpact:

Successful SQL injection attacks may expose confidential database information, alter or delete records, and in some cases allow attackers to gain complete control over the application's database system. This can result in data leaks and operational disruptions

Vulnerability path:

http://testfire.net/

Vulnerability parameter:

http://testfire.net/login.jsp

Sign In | Contact Us | Feedback | Search Go

AltoroMutual

DEMO SITE ONLY

ONLINE BANKING LOGIN | PERSONAL | SMALL BUSINESS | INSIDE ALTORO MUTUAL

PERSONAL
- Deposit Product
- Checking
- Loan Products
- Cards
- Investments & Insurance
- Other Services

SMALL BUSINESS
- Deposit Products
- Lending Services
- Cards
- Insurance
- Retirement
- Other Services

INSIDE ALTORO MUTUAL
- About Us
- Contact Us
- Locations
- Investor Relations
- Press Room
- Careers
- Subscribe

Online Banking with FREE Online Bill Pay
No stamps, envelopes, or checks to write give you more time to spend on the things you enjoy.

Real Estate Financing
Fast. Simple. Professional. Whether you are preparing to buy, build, purchase land, or construct new space, let Altoro Mutual's premier real estate lenders help with financing. As a regional leader, we know the market, we understand the business, and we have the track record to prove it

Business Credit Cards
You're always looking for ways to improve your company's bottom line. You want to be informed, improve efficiency and control expenses. Now, you can do it all - with a business credit card account from Altoro Mutual.

Retirement Solutions
Retaining good employees is a tough task. See how Altoro Mutual can assist you in accomplishing this feat through effective Retirement Solutions.

Privacy and Security
The 2000 employees of Altoro Mutual are dedicated to protecting your privacy and security. We pledge to provide you with the information and resources that you need to help secure your information and keep it confidential. This is our promise.

Win a Samsung Galaxy S10 smartphone
Completing this short survey will enter you in a draw for 1 of 5 Samsung Galaxy S10 smartphones! We look forward to hearing your important feedback.

Privacy Policy | Security Statement | Server Status Check | REST API | © 2023 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The AltoroJ website is published by IBM Corporation for the sole purpose of demonstrating the effectiveness of IBM products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. IBM does not assume any risk in relation to your use of this website. For more information, please go to http://www-142.ibm.com/software/products/us/en/subcategory/SW110.

Copyright © 2008, 2023, IBM Corporation, All rights reserved.

Sign In | Contact Us | Feedback | Search Go

AltoroMutual

DEMO SITE ONLY

ONLINE BANKING LOGIN | PERSONAL | SMALL BUSINESS | INSIDE ALTORO MUTUAL

PERSONAL
- Deposit Product
- Checking
- Loan Products
- Cards
- Investments & Insurance
- Other Services

SMALL BUSINESS
- Deposit Products
- Lending Services
- Cards
- Insurance
- Retirement
- Other Services

INSIDE ALTORO MUTUAL
- About Us
- Contact Us
- Locations
- Investor Relations
- Press Room
- Careers
- Subscribe

Online Banking Login

Username:

Password:

Login

Privacy Policy | Security Statement | Server Status Check | REST API | © 2023 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The AltoroJ website is published by IBM Corporation for the sole purpose of demonstrating the effectiveness of IBM products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. IBM does not assume any risk in relation to your use of this website. For more information, please go to http://www-142.ibm.com/software/products/us/en/subcategory/SW110.

Copyright © 2008, 2023, IBM Corporation, All rights reserved.

Recommendations:

- If parameterized statements are not feasible, use proper input validation and escaping mechanisms to sanitize user inputs before they are used in SQL queries. This helps prevent malicious code injection.
- Utilize stored procedures for database operations. This can help separate SQL code from application code and reduce the risk of SQL injection.
- Implement strict input validation for all user inputs, ensuring that data adheres to the expected format and structure.

4. Vulnerability Name

Broken Authentication

CWE/CVE: 285

OWASP Category: A07: Identification and Authentication Failures

Description:

Broken Authentication occurs when an application incorrectly implements authentication and session management mechanisms. Weak password policies, predictable session IDs, or improper login validation may allow attackers to bypass authentication and impersonate legitimate users.

BusinessImpact:

This vulnerability can allow unauthorized users to gain access to user accounts or even administrative panels. Attackers may steal sensitive data, modify records, or misuse user privileges, causing serious security and financial risks.

Vulnerability path:

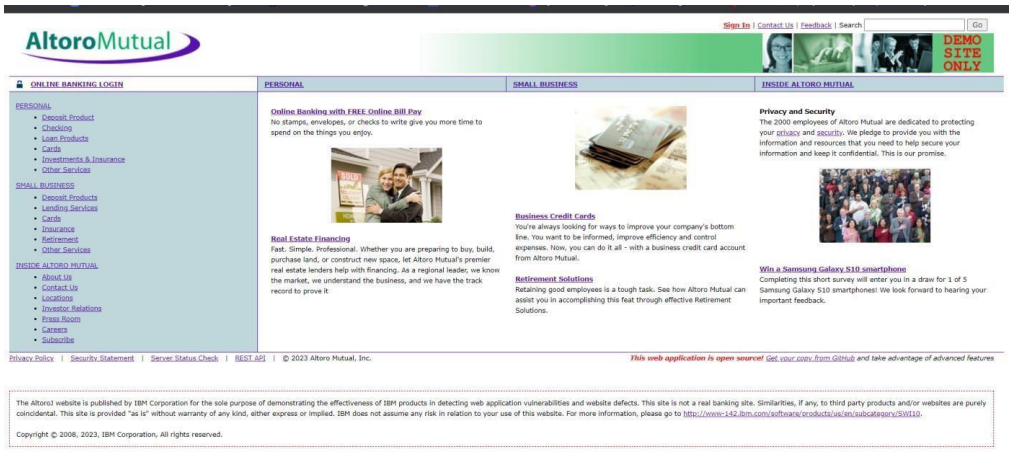
http://testfire.net/

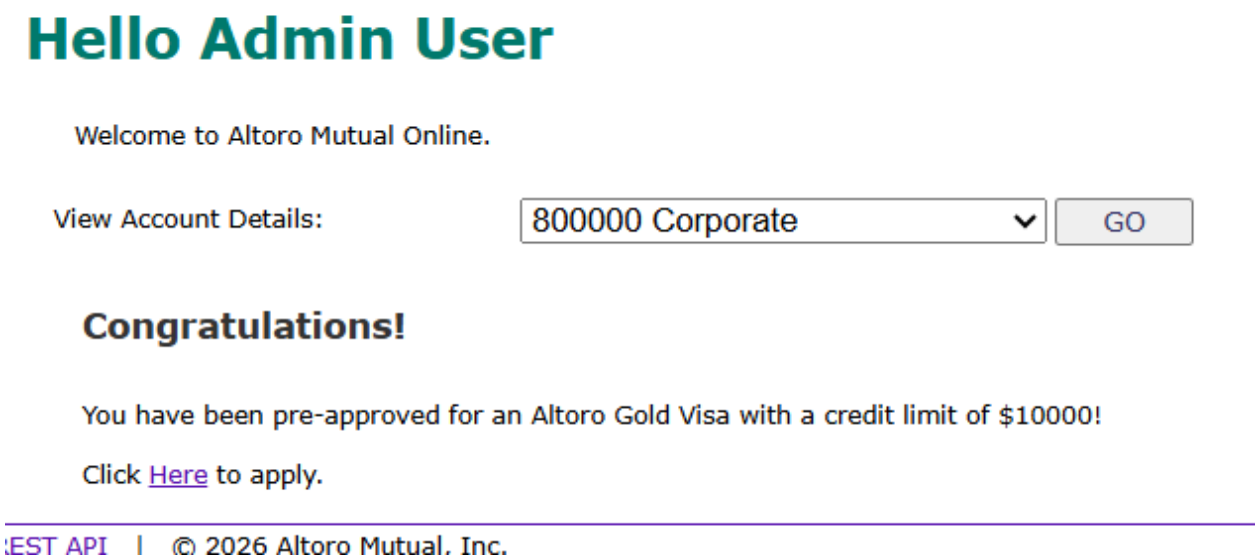
Vulnerability parameter:

http://testfire.net/login.jsp

.

- Access the URL





5. Vulnerability Name

Insecure Direct Object Reference (IDOR)

CWE/CVE:639

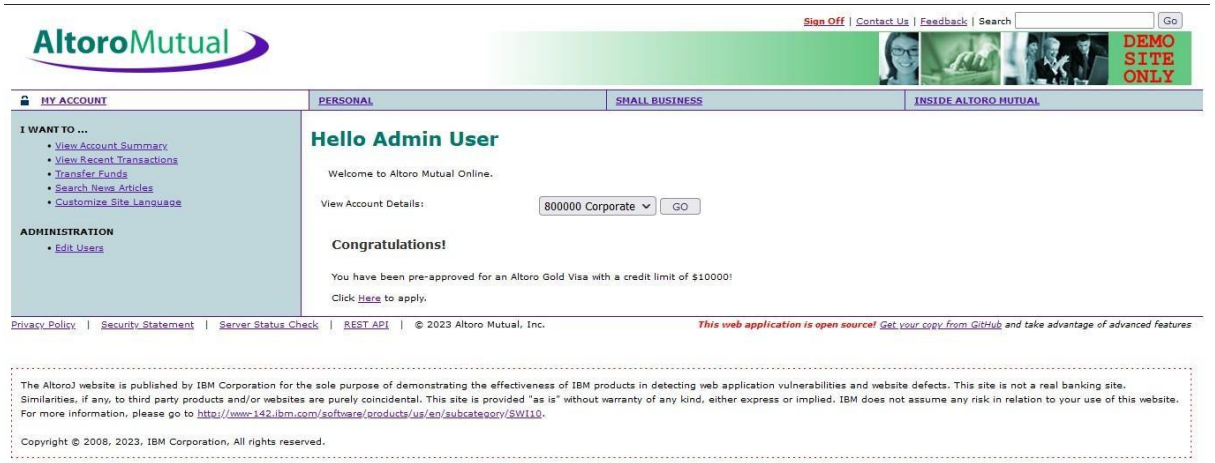
OWASP Category: A01: Broken Access Control

Description:

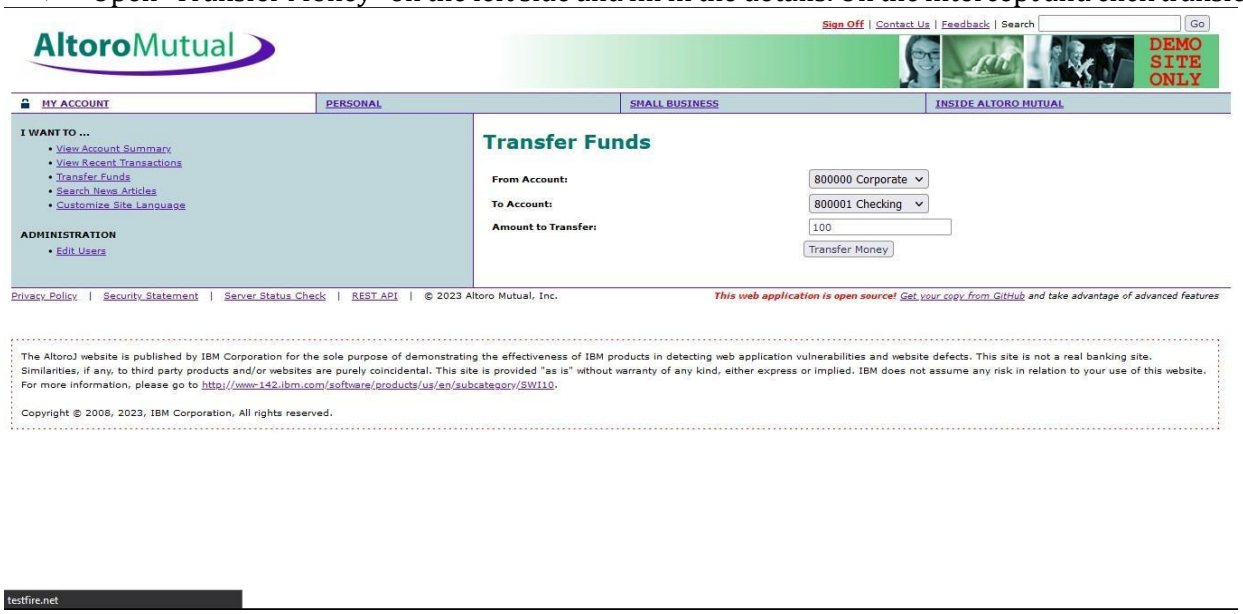
Insecure Direct Object Reference occurs when an application exposes internal objects such as files, database records, or user IDs through URLs or parameters without proper authorization checks. Attackers can manipulate these identifiers to access data belonging to other users.

BusinesImpact:

Exploiting this vulnerability can allow attackers to view or modify confidential information belonging to other users. This may lead to privacy violations, data breaches, and loss of trust among customers and stakeholders.



- Open “Transfer Money” on the left side and fill in the details. On the intercept and click transfer



testfire.net

Vulnerability path:
http://testfire.net/

Vulnerability parameter:
http://testfire.net/bank/transfer.jsp

6. Vulnerability Name

Security Misconfiguration

CWE/CVE: 732

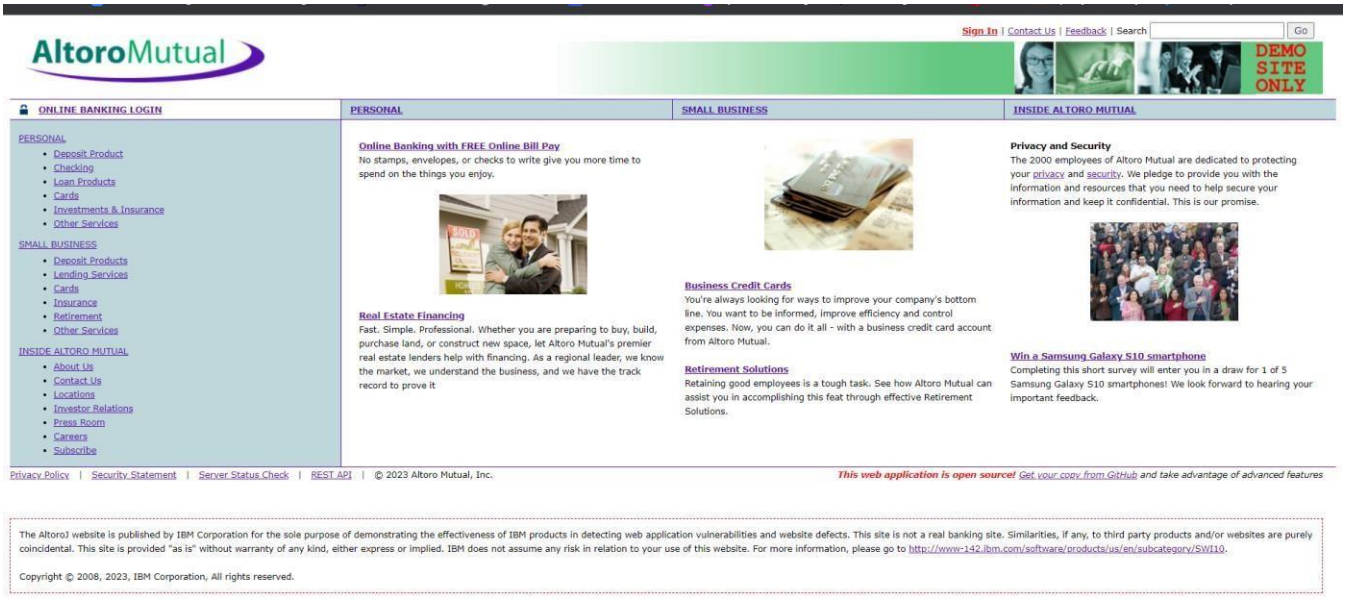
OWASP Category: A05: Security Misconfiguration

Description:

Security Misconfiguration happens when security settings within an application, server, or network are improperly configured. This can include unnecessary services running, default credentials, open directories, or improper permission settings.

BusinessImpact:

Attackers can exploit these misconfigurations to gain unauthorized access to systems or sensitive information. If not addressed, it can expose the entire application infrastructure to cyberattacks and system compromise.



Vulnerability path:

http://testfire.net/

Vulnerability parameter:

http://testfire.net/login.jsp

7. Vulnerability Name

Cross-Site Request Forgery (CSRF)

CWE/CVE: 352

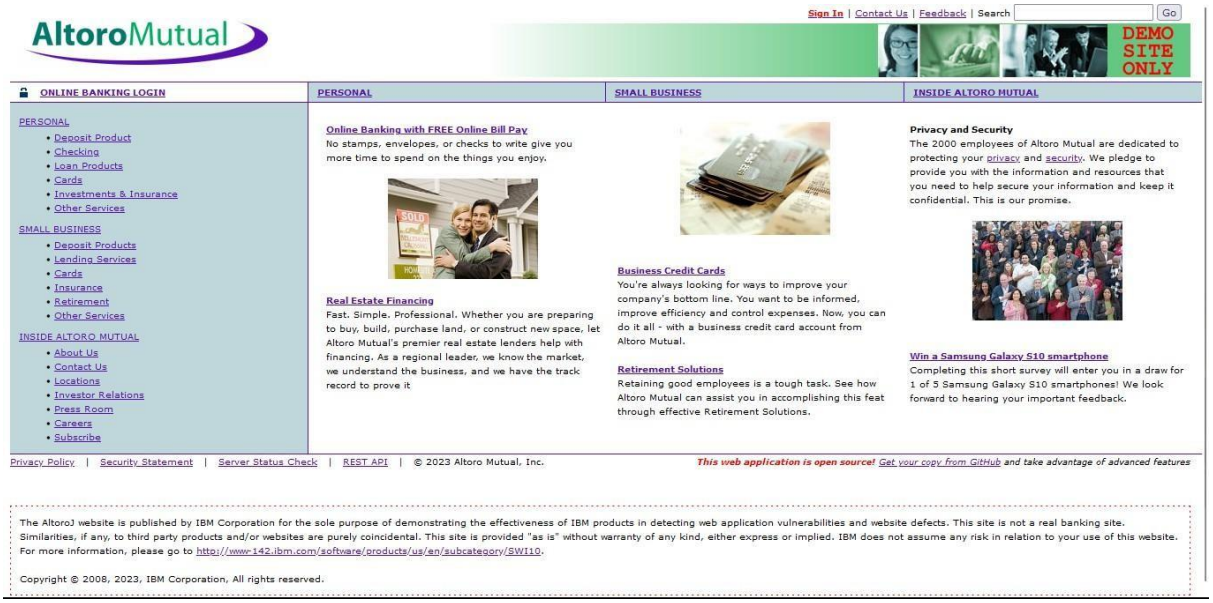
OWASP Category: A08: Cross-Site Request Forgery

Description:

CSRF is an attack that tricks authenticated users into performing unwanted actions on a web application without their knowledge. This usually happens when a malicious website sends a request to a trusted application where the user is already logged in.

BusinessImpact:

Attackers can force users to perform sensitive actions such as transferring funds, changing account details, or deleting data. This can result in financial loss, data manipulation, and loss of user trust



Vulnerability path:

http://testfire.net/

Vulnerability parameter:

http://testfire.net/bank/transfer.jsp

8. Vulnerability Name

Cleartext Transmission of Sensitive Information

CWE/CVE: 319

OWASP Category: Sensitive Data Exposure

Description:

This vulnerability occurs when sensitive information such as usernames, passwords, or personal data is transmitted over a network without encryption. Attackers monitoring the network traffic can intercept this information using packet-sniffing tools.

BusinessImpact:

If sensitive data is transmitted in cleartext, attackers may easily capture and misuse the information. This can lead to identity theft, account compromise, and major data security incidents

Vulnerability path:

http://testfire.net/

Vulnerability parameter:

http://testfire.net/login.jsp

Stage – 2

Overview: -

- This project focuses on the practical evaluation and security analysis of the proposed context-aware access control system. After defining the Zero Trust architecture in Stage-1, this phase concentrates on identifying potential security weaknesses and validating how effectively the system protects applications and network resources. The objective is to ensure that the implemented access control policies properly verify users, devices, and access conditions before granting connectivity to internal applications.
- In this stage, vulnerability assessment tools and security testing techniques are used to analyze the target environment. Security scanning tools such as Nessus and web application testing methods are applied to detect vulnerabilities including injection flaws, authentication weaknesses, misconfigurations, and access control issues. These tools simulate potential attack scenarios and generate reports that highlight security risks within the system. Each detected vulnerability is carefully examined to understand its cause, severity level, and possible impact on the application or organizational infrastructure.
- The analysis performed in this stage also helps demonstrate how context-aware access policies improve security compared to traditional network access models. By evaluating factors such as user identity verification, device security posture, location awareness, and application sensitivity, the system ensures that only authorized users are allowed to access specific resources. Any attempt to access the system from an untrusted device or suspicious location can be blocked automatically through policy enforcement.
- Additionally, the results obtained from vulnerability scanning provide valuable insights for strengthening the system's security posture. The findings help in recommending appropriate mitigation techniques such as input validation, secure authentication mechanisms, encryption protocols, and proper configuration management. These measures significantly reduce the attack surface and protect sensitive data from unauthorized access.
- Overall, Stage-2 plays a critical role in validating the effectiveness of the implemented Zero Trust access model. By performing vulnerability assessment and analyzing potential threats, this stage ensures that the system remains secure, reliable, and capable of protecting organizational applications frommoderncyber-attacks.

1. **VulnerabilityDetection:**
   Nessus is widely used for identifying security vulnerabilities within systems and networks. It scans target environments to detect issues such as outdated software, missing security patches, weak authentication mechanisms, and configuration errors that could be exploited by cyber attackers.
2. **NetworkDeviceScanning:**
   The tool is capable of analyzing different types of network devices including servers, routers, switches, firewalls, and workstations. During the scanning process, it examines open ports, running services, and installed applications to identify possible security risks.
3. **Plugin-Basedsystem:**
   Nessus operates using a plugin architecture that allows it to check for thousands of known vulnerabilities. These plugins are continuously updated by security researchers so that the scanner can detect newly discovered threats and vulnerabilities effectively.
4. **ComplianceVerification:**
   Nessus can also evaluate systems based on various security standards and compliance requirements. It helps organizations verify whether their infrastructure follows guidelines such as PCI-DSS, CIS security benchmarks, and other regulatory frameworks.
5. **FlexibleConfiguration:**
   The scanning process in Nessus can be configured according to organizational requirements. Security teams can define custom scan policies, choose specific targets, and decide which vulnerability categories should be analyzed during the scan.
6. **DetailedReporting:**
   After completing the scan, Nessus generates comprehensive reports that list identified vulnerabilities along with their severity levels and recommended remediation steps. These reports assist security administrators in prioritizing and fixing security issues.
7. **RegularSecurityMonitoring:**
   Organizations usually run Nessus scans periodically to maintain continuous monitoring of their network security. Frequent scanning helps detect newly introduced vulnerabilities and ensures that systems remain protected against emerging cyber threats.
8. **SecuritToolIntegration:**
   Nessus can be integrated with other cybersecurity tools and management platforms. This integration allows automated vulnerability management, better monitoring, and improved coordination between security systems.
9. **LicensingOptions:**
   Nessus provides both free and paid versions for users. The free version offers basic scanning capabilities, while the professional or commercial versions include advanced features, enhanced reporting, and extended vulnerability coverage.
10. **SimpleUserInterface:**
    Nessus provides an intuitive web-based interface that allows users to easily configure scans, monitor progress, and review results. This makes the tool suitable for both experienced cybersecurity professionals and beginners.

S. No	Vulnerability Name	Severity	Plugins
1.	Cross-site scripting (stored)	Low	Web application Scanner
2.	Broken Access Control	Medium	SSH weak HMAC Algorithms Supported
3.	SQL Injection	Medium	N/A

4.	Broken Authentication	Low	HSTS Missing from Server
5.	Insecure Direct Object Reference	Info	Service Detection
6.	Security Misconfiguration	Low	SSL cipher Block Chaining cipher suites
7.	Cross-Site Request Forgery	Low	HTTP Form- Based Authentication Detected

Target Website: testfire.net
Target IP Address: 54.83.41.36

Report:

1. **Vulnerability Name:** Cross-Site Scripting (Stored)

Severity: Low
Plugin: WebApplicationScanner
Port: N/A

Description:

Stored Cross-Site Scripting occurs when malicious scripts are permanently stored in a web application's database or other storage locations. When users access the affected page, the stored script is executed in their browser without their knowledge. This allows attackers to inject harmful JavaScript code that may manipulate the web page or steal user information.

Solution:

- Use prepared or parameterized statements when interacting with databases to minimize injection risks.
- Validate and sanitize all user inputs before storing them in the database.
- Ensure that dynamic data displayed on webpages is properly encoded to prevent script execution.

Business Impact:

- When harmful scripts are stored within application databases such as comment sections, logs, or message boards, they may be executed whenever users access that data. If high-privilege users or administrators interact with the compromised content, attackers may gain elevated privileges or access sensitive information. This can result in data exposure and loss of user trust.

2. **Vulnerability Name:** Broken Access Control

Severity: Medium
Plugin: SSH Weak HMAC Algorithms Supported
Port: N/A

Description:

Broken access control occurs when the application fails to properly enforce authorization checks. As a result, users may gain access to restricted resources or perform actions that they are not permitted to perform within the system.

Solution:

• Implement strong authentication and authorization mechanisms before allowing access to sensitive operations.
• Apply strict permission checks to ensure users can only perform actions allowed for their role.
• Improve session management by using secure session IDs, enforcing session timeouts, and regenerating tokens after login.

Business Impact:

If access restrictions are not properly implemented, unauthorized users may gain access to confidential data or perform unauthorized operations. This can lead to data leakage, service disruption, financial losses, and serious reputational damage for the organization.

3. **Vulnerability Name:** SQL Injection

Severity: Medium
Plugin: N/A
Port: 80 / 443

Description:

SQL Injection occurs when user-supplied input is directly incorporated into SQL queries without proper validation or sanitization. Attackers can manipulate these inputs to alter the database query, potentially retrieving or modifying sensitive data.

Solution:

• Use parameterized queries or prepared statements to separate SQL code from user input.
• Implement strict input validation to ensure only expected data formats are accepted.
• Use stored procedures and database access controls to minimize direct query manipulation.

Business Impact:

SQL Injection vulnerabilities can expose sensitive data stored in databases, including user credentials and confidential records. This may lead to major data breaches, financial loss, legal liabilities, and severe damage to the organization's reputation.

4. **Vulnerability Name:** Broken Authentication

Severity: Low
Plugin:HSTMissingfromHTTPSServer(PluginID:142960)
Port: 443

Description:

Broken authentication vulnerabilities occur when authentication and session management mechanisms are implemented incorrectly. This may allow attackers to impersonate legitimate users or gain unauthorized access to user accounts.

Solution:

Use multi-factor authentication (MFA) to strengthen user verification.
- Implement role-based access control (RBAC) to restrict user privileges.
- Deploy monitoring systems such as IDS/IPS to detect suspicious login activities.

Business Impact:

Weak authentication mechanisms can lead to unauthorized account access and identity compromise. If attackers gain access to sensitive user accounts, they may manipulate data or misuse system privileges, which can harm the organization's security and credibility.

5. **Vulnerability Name:** Insecure Direct Object Reference (IDOR)

Severity: Informational
Plugin: Service Detection (Plugin ID: 22964)
Port: 80 / 443

Description:

Insecure Direct Object Reference vulnerabilities occur when applications expose internal objects such as user IDs or file references through URLs or parameters without proper authorization checks. Attackers can manipulate these identifiers to access unauthorized resources.

Solution:

• Implement strict authorization checks for all requests accessing sensitive resources.
• Use indirect reference maps instead of exposing direct object identifiers.
• Apply security monitoring mechanisms to detect unauthorized access attempts.

Business Impact:

If attackers exploit this vulnerability, they may access or modify data belonging to other users. This could lead to privacy violations, data breaches, and loss of trust from customers and stakeholders.

6. **Vulnerability Name:** Security Misconfiguration

Severity: Low
Plugin: SSL Cipher Block Chaining Cipher Suites
Port: 443

Description:

Security misconfiguration occurs when systems or applications are not properly configured with secure settings. This may include default credentials, unnecessary services running, or incorrect permission settings.

Solution:

• Implement proper configuration management and review system changes regularly.
• Follow recommended security guidelines from software vendors.
• Conduct routine security audits and compliance checks.

Business Impact:

Improper configurations may expose sensitive system resources to attackers. This can lead to unauthorized access, data leaks, or exploitation of system weaknesses, affecting the overall security posture of the organization.

7. **Vulnerability Name:** Cross-Site Request Forgery (CSRF)

Severity: Low
Plugin: HTTP Form-Based Authentication Detected
Port: 8080 / 443

Description:

CSRF attacks trick authenticated users into performing unintended actions on a web application. Attackers often achieve this through malicious links or scripts that send unauthorized requests to the target application while the user is logged in.

Solution:

- Use anti-CSRF tokens to verify legitimate user requests.
- Configure cookies with the SameSite attribute to restrict cross-site usage.
- Implement Content Security Policy (CSP) to limit the execution of unauthorized scripts.

Business Impact:

Successful CSRF attacks may allow attackers to perform actions such as modifying account details, transferring funds, or altering sensitive data. This can compromise the integrity of the application and damage the organization's credibility and user trust.

S. NO	VULNERABILITY NAME	SEVERITY	PLUGINS
1.	Cross-site scripting (DOM based XSS)	Medium	Multiple XSS
2.	jQuery 1.3<3.5.0 Multiple XSS	Medium	CGI Abuse: XSS
3.	Information exposure (web server HTTP header internal IP disclosure)	Low	Webserver HTTP Header Internal IP Disclosure

TARGET WEBSITE: vit.ac.in
TARGET IP ADDRESS: 122.184.65.22

Report

1. **Vulnerability Name:** Cross-Site Scripting (DOM-Based XSS)

Severity: Medium
Plugin: Multiple XSS
Port: 443

Description:

DOM-based Cross-Site Scripting occurs when a web application processes user input within the browser's Document Object Model (DOM) without proper validation. In this type of vulnerability, malicious JavaScript code is executed directly in the user's browser when the web page dynamically updates its content. The Document Object Model acts as an interface that allows scripts to modify the structure, content, and styling of web pages. If user input is not properly handled, attackers can manipulate the DOM and inject harmful scripts that execute when the page is loaded.

Solution:

- Validate and sanitize all user inputs before processing them within the application.
- Ensure proper output encoding when displaying dynamic data in the browser.
- Avoid insecure DOM manipulation functions such as `innerHTML` or `document.write` that may execute untrusted scripts.
- Use secure and updated JavaScript libraries or frameworks that provide built-in protection against DOM-based vulnerabilities.

Business Impact:

If malicious scripts are injected into areas frequently accessed by users, they may be executed whenever the page is opened. Attackers can exploit this vulnerability to steal session cookies, impersonate users, or access sensitive information. If privileged users execute the malicious script, attackers may gain unauthorized access to important data or perform actions on behalf of legitimate users.

2. **Vulnerability Name:** jQuery 1.2 < 3.5.0 Multiple XSS

Severity: Medium
Plugin: CGI Abuse: XSS
Port: 443

Description:

Older versions of the jQuery library contain multiple security vulnerabilities that may allow Cross-Site Scripting attacks. When applications use outdated versions of jQuery, attackers can exploit weaknesses in the library to inject malicious scripts into web pages. These scripts may execute in the user's browser, especially when input data is not properly validated or sanitized.

Solution:

- Upgrade the jQuery library to the latest secure version to remove known vulnerabilities.
- Monitor security advisories and updates related to third-party libraries used in the application.
- Implement a Content Security Policy (CSP) to restrict the execution of unauthorized scripts.
- Review application code to ensure user inputs are properly escaped or sanitized before being processed.

Business Impact:

If attackers exploit vulnerabilities in outdated JavaScript libraries, they may inject malicious code into the web application. This can lead to session hijacking, unauthorized data access, and potential compromise of user accounts. Such incidents can affect the reliability of the application and harm the organization's reputation.

3. **Vulnerability Name:** Information Exposure (Web Server HTTP Header Internal IP Disclosure)

Severity: Low
Plugin: Web Server HTTP Header Internal IP Disclosure
Port: 80

Description:

This vulnerability occurs when a web server unintentionally reveals internal system information through HTTP response headers. Internal IP addresses or infrastructure details may be exposed to external users, which can help attackers gather information about the internal network architecture.

Solution:

- Review server configuration files such as Apache or Nginx settings to ensure internal addresses are not exposed in HTTP headers.
- Remove unnecessary server information from response headers like **Server** or **X-Powered-By**.
- Configure reverse proxies or load balancers to hide internal network details from external requests.
- Regularly audit server configurations to ensure sensitive information is not disclosed.

Business Impact:

Although this vulnerability may appear minor, exposing internal infrastructure details can assist attackers during reconnaissance. Knowledge of internal IP addresses or system configurations can make it easier for attackers to plan further attacks. Preventing such information leakage helps maintain stronger security and protects organizational infrastructure.

Stage – 3

Title :

Design and Apply Context-Aware Access Controls Based on User Identity, Device Posture, Location, and Application Risk

- Context-aware access control is an important concept in **Zero Trust Architecture**, which provides dynamic and intelligent security for modern organizations. Instead of granting access only based on username and password, this approach evaluates multiple real-time factors such as user identity, device security status, location, and application sensitivity. This helps organizations make better access decisions like allowing, blocking, or challenging a user request based on the current risk level.
- The implementation of context-aware access control can be achieved using solutions such as **Zscaler Private Access**. These systems integrate with identity providers like **Microsoft Azure Active Directory** or **Okta** to verify user identity and enforce multi-factor authentication. Policies can then be created based on user roles, departments, or group memberships to ensure that only authorized users can access specific applications.
- Another important factor is **device posture**, which evaluates the security condition of the user's device. The system checks whether the device has updated antivirus software, encryption enabled, and the latest security patches installed. If a device does not meet security requirements, access may be restricted or redirected for remediation.
- Location and network environment are also considered when making access decisions. Access requests from trusted locations such as corporate networks may be allowed, while requests from unknown or risky locations may require additional authentication. Furthermore, applications are categorized based on their risk level, ensuring that sensitive systems receive stronger protection.
- By combining these contextual factors, organizations can create a flexible and secure access control system that protects critical resources while supporting modern remote and mobile work environments. This approach ensures continuous verification of users and devices, thereby strengthening overall cybersecurity.

Conclusion

Stage 1

- Stage 1 focuses on understanding the fundamental concept of **context-aware access control** and its importance in modern cybersecurity systems. Traditional access control models rely mainly on usernames and passwords, which are no longer sufficient to protect sensitive digital resources. This stage explores how organizations can strengthen their security by incorporating multiple contextual factors such as user identity, device security status, user location, and the sensitivity of the application being accessed.
- The study also introduces the concept of **Zero Trust architecture**, which assumes that no user or device should be trusted automatically. Every access request must be verified continuously before granting permission. By analyzing these security principles, Stage 1 provides the theoretical foundation required to design intelligent access control mechanisms that protect enterprise systems from unauthorized access and cyber threats.

Stage 2

Stage 2 focuses on **security assessment and vulnerability identification** in systems before implementing advanced access control mechanisms. Using vulnerability scanning tools such as Nessus, the system is analyzed to identify potential security weaknesses, configuration issues, and outdated components that may expose the network or applications to cyber attacks.

The scan results classify vulnerabilities based on their severity levels such as low, medium, and high risk. These findings help administrators understand the areas where security improvements are required. Appropriate remediation actions such as software updates, configuration changes, and secure coding practices can then be applied. This stage highlights the importance of continuous monitoring and vulnerability management to ensure that the system environment remains secure before enforcing context-aware access policies

Stage 3

Stage 3 involves the **implementation of context-aware access control policies** that dynamically regulate access to applications and systems. Instead of relying on a single authentication factor, the system evaluates multiple contextual attributes including the user's identity, device posture, geographic location, and the risk level of the application.

By combining these factors, the system can make intelligent access decisions such as allowing access, blocking suspicious requests, or requiring additional authentication steps. This implementation aligns with **Zero Trust security principles**, ensuring that access is granted only when all security conditions are satisfied. As a result, organizations can significantly reduce the risk of unauthorized access, data breaches, and internal threats while maintaining secure and efficient operations.

Future Scope

Stage 1 – Future Scope of Context-Aware Access Control

The future of context-aware access control systems is highly promising as organizations increasingly adopt **Zero Trust security frameworks** to protect their digital environments.

Some important future developments include:

• **Artificial Intelligence Integration:** AI and machine learning can analyze user behavior and automatically detect suspicious access patterns.
• **Advanced Authentication Methods:** Technologies such as biometric authentication and behavioral analytics will further strengthen identity verification.
• **Cloud Security Expansion:** As organizations migrate to cloud infrastructure, context-aware access control will play a crucial role in protecting cloud resources.
• **Automated Security Policies:** Access policies will dynamically adjust based on real-time risk levels and security intelligence.

Stage 2 – Future Scope of Security Testing and Vulnerability Analysis

Security testing will continue evolving to support stronger cybersecurity frameworks. Vulnerability scanning and penetration testing will become more intelligent and automated.

Key future developments include:

• **AI-Based Vulnerability Detection:** Advanced tools will use machine learning algorithms to detect security flaws more efficiently.
• **Continuous Security Monitoring:** Real-time monitoring systems will detect threats immediately and trigger automatic security responses.
• **Integration with Threat Intelligence Platforms:** Security tools will connect with global threat databases to identify new vulnerabilities quickly.
• **Security for Emerging Technologies:** Vulnerability testing will expand to cover IoT devices, mobile applications, and cloud platforms.

Stage 3 – Future Scope of Context-Aware Access Control Implementation

The implementation of context-aware access control systems can be enhanced with additional technologies and integrations in the future.

Possible improvements include:

• **Advanced Device Security Monitoring:** Real-time evaluation of device health and security compliance.
• **AI-Driven Risk Analysis:** Machine learning algorithms that dynamically adjust access policies basedonuserbehavioranddetectethreats.
• **Secure Access Service Edge (SASE) Integration:** Combining network security and access control intoaunifiecloud-basedsecurityplatform.
• **Privileged Access Management:** Providing controlled and monitored access to administrators, vendors,andexternalusers.
• **Automated Access Provisioning:** Automatically granting or revoking user access when roles or responsibilitieschange.
• **Behavioral Analytics:** Monitoring user activity to detect unusual access patterns and trigger additional authentication measures.

Topics Explored

1. Context-Aware Access Control
2. Zero Trust Architecture
3. User Identity Management
4. Device Posture Assessment
5. Location-Based Access Policies
6. Application Risk Classification
7. Threat Intelligence and Security Monitoring
8. Network Security Architecture
9. Vulnerability Assessment

Tools Explored

• Nessus Scanner – Used to identify vulnerabilities, security misconfigurations, and potential risks in web applications and network systems.